

Защита и оценка уровня безопасности ИС. Этапы оценки СОИБ

Сабина Жигальская

Специалист по комплексной защите информации

Skillbox

Цели урока

- ✓ Познакомиться с уровнями защиты ИС и с тем, как они устроены
- ✓ Изучить, что такое СОИБ

Защита ИС

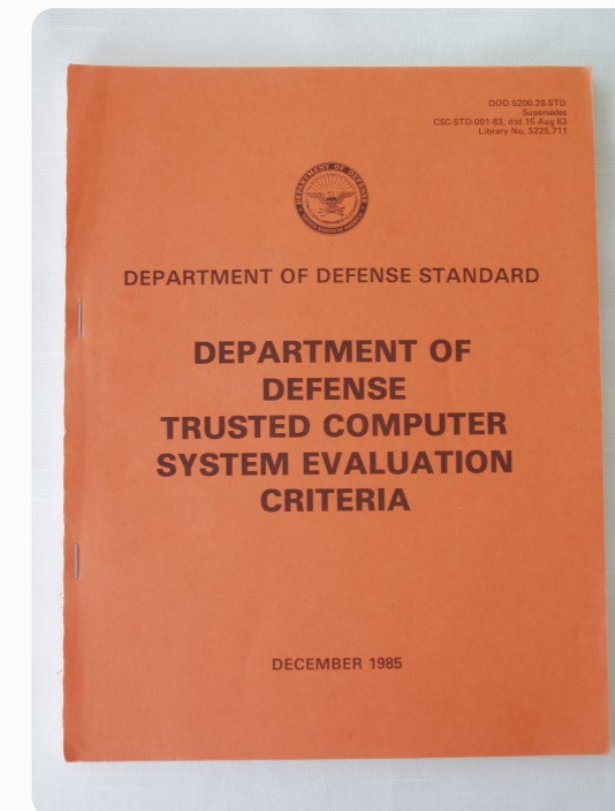
Абсолютно защищённой системы не существует, но есть уровни, которые позволяют определить степень защиты системы.

Чем выше уровень защиты, тем лучше, но максимальный уровень защиты обязателен не для всех систем.



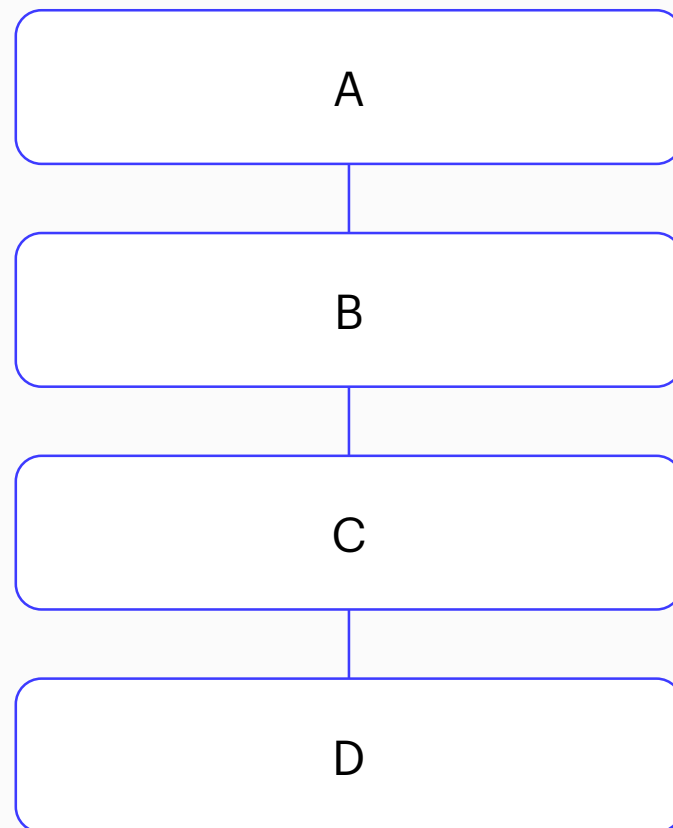
Оранжевая книга

Стандарт TCSEC (Trusted Computer System Evaluation Criteria) — стандарт критериев определения безопасности компьютерных систем, также известный как **Оранжевая книга**.



Уровни безопасности

Существует 4 уровня безопасности:



Уровень D — это нулевой уровень, безопасность на нём фактически отсутствует.

Такой уровень не подойдёт ни одной серьёзной компании.

Уровни безопасности

Уровень С — дискреционная защита, то есть связанная с разграничением прав.

C1 (старые версии ПО Unix)	C2 (Oracle 7)
- у каждого пользователя есть доступ только к своим объектам - аутентификация пользователей - все базы данных защищены от внешнего воздействия - средства для защиты ИС протестированы	- все объекты подвергаются строгому контролю доступа - каждый пользователь идентифицируется уникальным образом, то есть каждое действие, совершённое пользователем, записывается

Уровни безопасности

Уровень В — мандатная защита. Мандаты — это метки секретности (секретно, совершенно секретно) в БД, которые ассоциируются с конкретным пользователем.

B1 (HP UX)	B2 (Trusted Xenix)	B3 (Getronics)
• изолированные процессы в БД • исходный код ИС протестирован на безопасность • политика ИБ неформальная	• система регистрации событий, происходящих в ИС • политика ИБ формальная (полное описание всех процессов безопасности) • высокий уровень защиты БД	• система регистрации событий, которые несут угрозу ИС • администратор безопасности • механизмы, которые позволяют восстановить систему после сбоя

Уровни безопасности

Уровень А — верифицируемая безопасность, то есть максимальная защита.

На этом уровне всего один подкласс **A1**:

- все процессы, которые происходят в системе, защищены
- все тестирования на проникновение пройдены успешно

Уровнем А обладает система полётов от Boeing.



СОИБ

СОИБ (система обеспечения информационной безопасности) — комплекс организационных и программных мер, функционирующих по определённым правилам.

В СОИБ входят средства:

- защиты информации
- контроля эффективности защиты информации
- управления ИБ



Оценка СОИБ

Для того чтобы построить СОИБ, нужно провести следующие оценки ИС:

- оценка по эталону — выбрать стандарт (например: PCI DSS, ISO, ГОСТ) и проверить систему на соответствие ему
- риск-ориентированная оценка — проанализировать возможные риски
- оценка по экономическим показателям — оценить затраты

На основе всех этих оценок выводится полная оценка информационной безопасности системы.

Изучение темы СОИБ

Тема системы обеспечения информационной безопасности очень важна, так как от неё зависит сохранность данных, а значит, репутация бизнеса и его экономические показатели.

Именно поэтому на тему СОИБ пишется много статей, книг и научных публикаций.



Выводы урока

- ✓ Оценкой безопасности ИС занимаются специалисты по организационной защите информации, но общие знания того, как она устроена, полезны всем, кто работает с ИБ
- ✓ Существует 4 уровня безопасности, которые подробно описаны в **Оранжевой книге** или **Стандарте TCSEC**.
Уровень А — самый высокий, уровень D — самый низкий
- ✓ **СОИБ** — комплекс организационных и технических мер, направленных на защиту информации и функционирующих по определённым правилам

Выводы модуля

В этом модуле мы обсудили безопасность операционной системы Linux и узнали следующее:

- ✓ Одна из главных задач системного администратора — обеспечение безопасности каждого компьютера в организации
- ✓ Базовые приёмы включают наличие пароля у каждого пользователя и своевременное обновление системы
- ✓ Также мы узнали про 4 уровня ИБ и познакомились с СОИБ
- ✓ Существуют «базовые» и «продвинутые» техники безопасности
- ✓ Продвинутые техники — использование соответствующего программного обеспечения, типа AppArmor, PolKit и PAM